

ARNAB ROY

📞 +1 (857) 317-1327 ✉️ arnab.cyberapp@gmail.com 💼 linkedin.com/in/arnab-roy-/ 🌐 Portfolio

EXPERIENCE

Application Security Consultant

Apr 2025 – Present

ASquare Ideas, Boston, MA

- Built a unified **Application Security Dashboard** consolidating **SCA**, **SAST**, and **Secret** findings from **JFrog** and **SonarQube**, providing security visibility and SLA-driven remediation tracking for developers, application owners, and executive leadership.
- Rolled out **JFrog SCA Reachability** by integrating Frogbot into Azure DevOps CI/CD pipelines, enabling reachability-based vulnerability prioritization and improving remediation efficiency.
- Engineered an automated **supply chain threat intelligence** platform that monitored security research from Semgrep, Endor Labs, Socket, and JFrog, leveraged AI agents to identify compromised packages, and validated enterprise exposure against **JFrog Artifactory**.
- Assessed enterprise exposure during the **Shai Hulud** and **Nx Singularity** supply chain attacks, determined application blast radius, and coordinated remediation with development teams.
- Established a risk-based approval process for third-party packages by evaluating dependency risk, licensing, known vulnerabilities, and package health before enterprise adoption.
- Developed a risk-based secrets remediation strategy for legacy .NET applications, identifying framework modernization as a prerequisite for secure secret management and enterprise-scale remediation.

Information Security Analyst

Jun 2024 – Jan 2025

Intello Group, Boston, MA

- Led **Threat Modeling** and security architecture reviews for five critical applications, identifying design flaws and recommending **Zero Trust** architecture aligned with NIST CSF and OWASP.
- Designed an enterprise vulnerability management program integrating **SAST**, **DAST**, Nessus, and OWASP ZAP, prioritizing remediation using business impact, CVSS, and EPSS.

Associate Security Researcher

Jun 2023 – Jun 2024

Semgrep, Boston, MA

- Developed over **600 SAST rules** for npm, Maven, PyPI, and Go modules, improving detection of software supply chain vulnerabilities across multiple ecosystems.
- Automated CI/CD security rule generation using vulnerability intelligence from NVD, OSV, GitHub Security Advisories, and vendor advisories, increasing detection accuracy by **25%**.

IT Audit Analyst Co-op

Jul 2022 – Dec 2022

Fidelity Investments, Boston, MA

- Led comprehensive audits across 12 databases, resolving security and compliance gaps aligned with corporate governance policies and **Zero Trust** principles.
- Spearheaded IAM security audits reviewing access control policies, reducing permission creep by eliminating 30 redundant users and roles, enforcing least privilege under **Zero Trust** architecture.

SKILLS

Languages	Python, Go, Bash, PowerShell, JavaScript, C++
Cloud & DevOps	AWS, Azure, Azure DevOps, Docker, Kubernetes, GitHub Actions
Application Security	SAST, DAST, SCA, Threat Modeling, Secure SDLC, Supply Chain Security, Vulnerability Management, DevSecOps
Security Tools	JFrog, SonarQube, Semgrep, Burp Suite, OWASP ZAP, Nessus, Endor Labs, Wiz, GitHub Advanced Security
Frameworks	OWASP Top 10, OWASP ASVS, MITRE ATT&CK, NIST CSF, CVSS, EPSS
Other	Power BI, Swagger/OpenAPI, Git, Claude AI, Redis, MariaDB

EDUCATION

Master of Cybersecurity

Sep 2021 – May 2023

Northeastern University, Boston, MA

Bachelor of Technology

May 2017 – Apr 2021

KIIT University, India

CERTIFICATES & PUBLICATIONS

- | | | | |
|-----------------------------|----------|---|----------|
| • OWASP BASC 2026 Presenter | 2026 | • AWS Certified Cloud Practitioner | Jul 2022 |
| • CompTIA CySA+ | Apr 2024 | • CompTIA Security+ | Jul 2021 |
| • INE eJPT | May 2025 | • AI-Based Mobile Edge Computing (Springer) | Feb 2022 |